

CNO IV: SEGURIDAD INFORMÁTICA

ACT
04

UNA PÁGINA DEMASIADO CONVINCENTE

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

FRIEDA MARÍA ORTIZ LÓPEZ

184346

Contenido

Objetivo de la actividad	3
Descripción del escenario.	3
Configuración del Entorno.	3
Creación de la página web	3
Configuración del laboratorio	5
Inicio de Social-Engineering-Toolkit y Credential Harvester	6
¿Qué es Credential Harvester?.....	6
Configuración e inicialización de Credential Harvester	8
Evidencias y descripción del funcionamiento	9
Explicación del flujo de captura de información.	11
Diagrama del flujo	11
Diferencia entre captura de credenciales y vulneración de una contraseña	12
Indicadores de phishing.....	12
Controles de seguridad propuestos.....	13
Conclusión.	14
Referencias.	14

Objetivo de la actividad.

Simular, dentro de un laboratorio controlado, un ataque de ingeniería social mediante *Social-Engineer Toolkit (SET)*. Para ello, se utilizará una página web ficticia de inicio de sesión con el fin de observar cómo la información introducida en un formulario puede ser enviada mediante una petición HTTP y registrada por un servidor.

A partir de la práctica se busca comprender el funcionamiento básico de una técnica de captura de credenciales, identificar los elementos que pueden hacer convincente una página de phishing y reconocer indicadores que permitan detectar este tipo de engaños. También se pretende analizar medidas de seguridad que ayuden a prevenir o reducir el impacto de ataques de phishing.

Descripción del escenario.

El escenario que se plantea es que una persona recibe un supuesto aviso relacionado con la actualización o renovación de sus credenciales por motivos de seguridad. El enlace del mensaje dirige a un portal que aparenta pertenecer a una organización y muestra un aviso indicando que la sesión ha expirado, solicitando nuevamente un usuario y una contraseña. El objetivo de este diseño es simular una situación común de phishing en la que se intenta generar urgencia para que la persona introduzca información de acceso.

Para desarrollar la simulación se creó una página web ficticia correspondiente a un portal corporativo inventado denominado *Vantex Solutions*. La página simula la página de inicio de sesión con un mensaje sobre que la sesión habría cerrado por motivos de seguridad.

La simulación se realizará exclusivamente dentro de una máquina virtual con Kali Linux y en un entorno local de laboratorio. No se utilizarán páginas, dominios ni credenciales reales, y el servidor no será publicado hacia Internet y no se utilizarán los conocimientos obtenidos de la actividad de manera perjudicial a otros. Esta actividad es únicamente de carácter educativo.

Configuración del Entorno.

Creación de la página web

Para esta actividad se desarrolló una página web ficticia de autenticación correspondiente a una organización inventada llamada *Vantex Solutions*. El sitio fue elaborado utilizando HTML y CSS e incluye los elementos:

- nombre de la organización
- campo de usuario
- campo de contraseña
- botón de inicio de sesión
- mensaje acerca de que la sesión ha expirado.

Portal Corporativo - Acceso exclusivo para colaboradores

Vantex Solutions
PORTAL DEL COLABORADOR

[Iniciar sesión](#) [Recursos Humanos](#) [Soporte TI](#) [Directorio](#)

ACCESO ÚNICO CORPORATIVO

Todo tu trabajo, en un solo lugar

Ingresar con tu cuenta corporativa para consultar tu correo, nómina, solicitudes y documentos internos.

- Correo y calendario corporativo
- Recibos de nómina y prestaciones
- Solicitudes de vacaciones y permisos
- Políticas y documentos internos

¿Problemas de acceso? Comunícate con Soporte TI ext. 4521 o soporte.ti@vantexsolutions.com

Iniciar sesión
Usa tu cuenta corporativa para continuar

⚠ Su sesión ha expirado por motivos de seguridad. Es necesario que inicie sesión nuevamente. De lo contrario, podría resultar en la **suspensión de su cuenta**.

Usuario corporativo
empleado demo

Contraseña

☐ Mantener sesión iniciada [¿Olvidaste tu contraseña?](#)

Iniciar sesión

Este equipo debe cumplir con la **Política de Uso Aceptable** de la empresa

Windows taskbar: 10:36 a.m., 29/ago./2026

El formulario fue configurado utilizando el método HTTP POST. Este método permite que los valores introducidos en los campos del formulario sean enviados al servidor dentro del cuerpo de la petición HTTP, a diferencia de GET, que normalmente incorpora los parámetros en la URL. Cuando un formulario utiliza **method="POST"**, los datos del formulario se incluyen en el cuerpo de la solicitud enviada al servidor. Se utilizan los parámetros username y password, que contienen los valores introducidos en los campos.

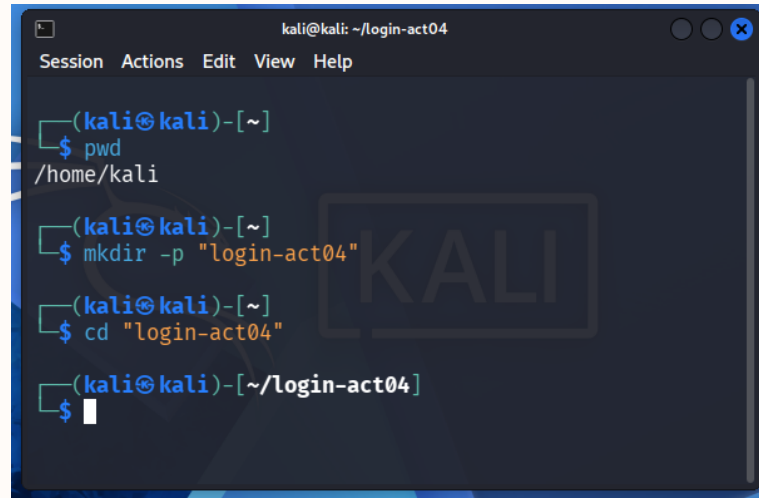
```
1 <form method="POST" action="/">
2   <div class="form-group">
3     <label for="username">Usuario corporativo</label>
4     <input
5       type="text"
6       id="username"
7       name="username"
8       placeholder="empleado.demo"
9       required
10    />
11  </div>
12
13  <div class="form-group">
14    <label for="password">Contraseña</label>
15    <input
16      type="password"
17      id="password"
18      name="password"
19      placeholder="*****"
20      required
21    />
22  </div>
23
24  [...]
25 </form>
```

Posteriormente, *Credential Harvester* recibirá la petición HTTP generada por el formulario y podrá registrar dichos.

Configuración del laboratorio

Para comenzar la práctica se utilizó una máquina virtual de Kali Linux con Oracle VirtualBox mediante Oracle VirtualBox. Dentro de Kali se utilizará *Social-Engineer Toolkit (SET)* para alojar la página ficticia.

Dentro de Kali Linux, creé una carpeta para la actividad con el nombre *login-act04* para almacenar los archivos de la página web.



```
kali@kali: ~/login-act04
Session Actions Edit View Help

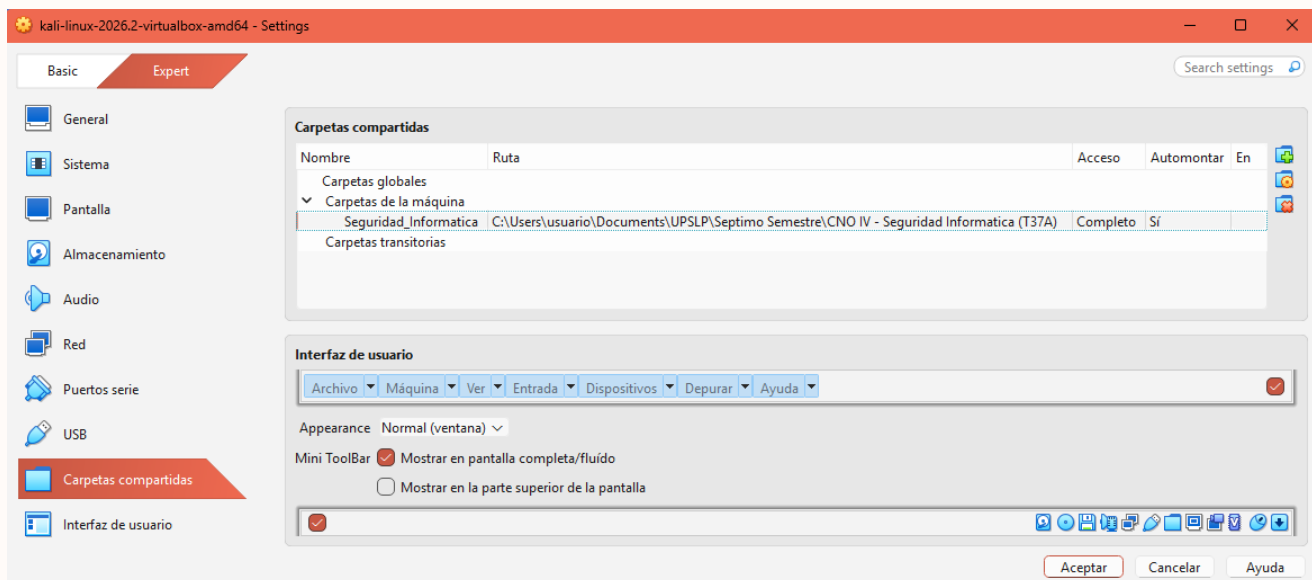
(kali@kali)-[~]
$ pwd
/home/kali

(kali@kali)-[~]
$ mkdir -p "login-act04"

(kali@kali)-[~]
$ cd "login-act04"

(kali@kali)-[~/login-act04]
$
```

Posteriormente configuré una carpeta compartida, pues la página web se realizó desde el equipo anfitrión. Ahora Kali tiene acceso a los archivos del index y los estilos.



Cuando ya se había configurado la carpeta compartida, desde la terminal se verificó el acceso a esta y a los archivos. Se hizo la copia del archivo `index.html` con el comando `cp`, y se verificó que sí estuviera en la carpeta de destino con `ls -l`.


```
kali@kali: ~/login-act04
Session Actions Edit View Help

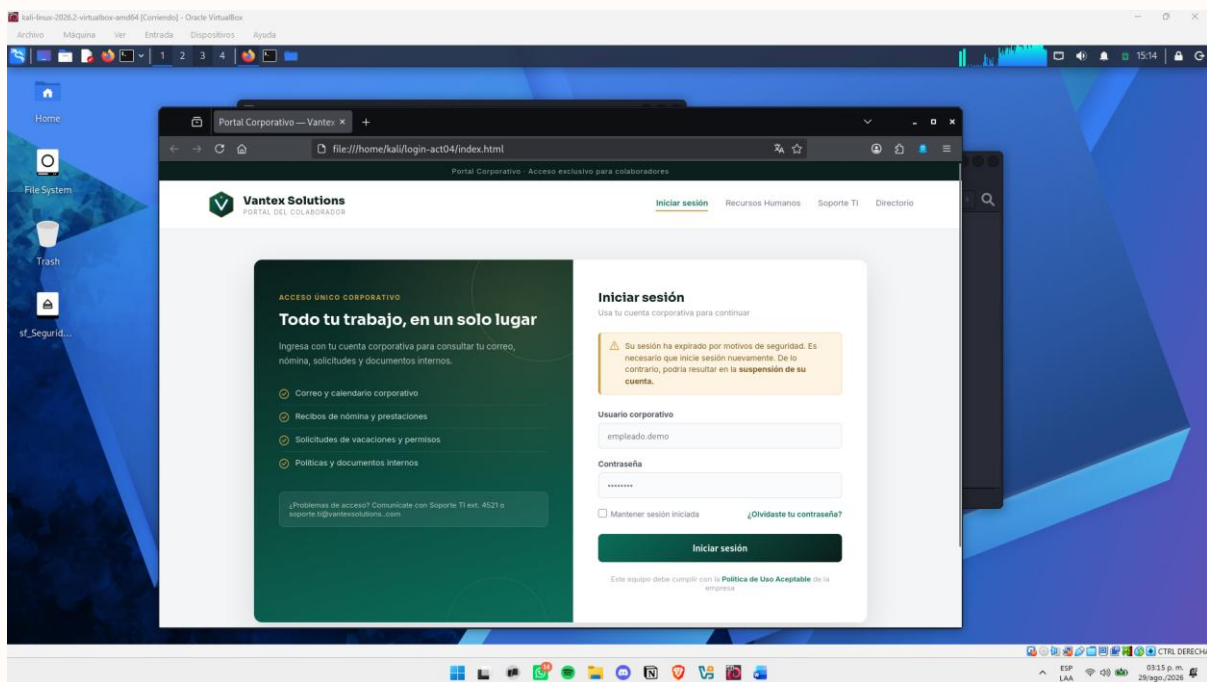
(kali@kali)~/login-act04
$ ls /media/sf_Seguridad_Informatica/Act04
index.html  reporte-capturas

(kali@kali)~/login-act04
$ cp /media/sf_Seguridad_Informatica/Act04/index.html ~/login-act04

(kali@kali)~/login-act04
$ ls
index.html

(kali@kali)~/login-act04
$
```

Después de copiar el index se comprobó que la página abre correctamente desde Firefox. Antes de ser utilizada con la herramienta de SET



Inicio de Social-Engineering-Toolkit y Credential Harvester

¿Qué es Credential Harvester?

Credential Harvester es un módulo de Social Engineer Toolkit que tiene por función recibir y registrar la información enviada desde formularios web, específicamente aquellos que tienen campos de usuario y contraseña. Dentro de una simulación de phishing. Actúa como el servidor que recibe los datos que una persona introduce en una página que fue preparada para el laboratorio.

Cuando un usuario envía el formulario, los valores se transmiten en una petición HTTP hacia el servidor de SET. El módulo procesa los parámetros, identifica campos relacionados con credenciales y los registra para su consultarlos después.

Para comenzar, desde la terminal se ejecutó el comando `sudo setoolkit` para iniciar la herramienta de Social-Engineer Toolkit. Esta herramienta será utilizada para configurar el módulo de **Credential Harvester Attack Method** para capturar la información del formulario web.

Dentro de la herramienta, se muestra el menú con opciones para diferentes módulos. Seleccionaremos la opción 1: **Social Engineering Attacks**.

```
kali@kali: ~  
Session Actions Edit View Help  
Visit: https://www.trustedsec.com  
  
It's easy to update using the PenTesters Framework! (PTF)  
Visit https://github.com/trustedsec/ptf to update all your tools!  
  
There is a new version of SET available.  
Your version: 8.0.3  
Current version: 8.1.3  
  
Please update SET to the latest before submitting any git issues.  
  
Select from the menu:  
1) Social-Engineering Attacks  
2) Penetration Testing (Fast-Track)  
3) Third Party Modules  
4) Update the Social-Engineer Toolkit  
5) Update SET configuration  
6) Help, Credits, and About  
  
99) Exit the Social-Engineer Toolkit  
set>
```

Dentro del menú de ataques de ingeniería social se seleccionó el número 2: **Website Attack Vectors**. Este apartado contiene diferentes métodos que utilizan páginas web.

```
kali@kali: ~/login-act04  
Session Actions Edit View Help  
Visit: https://www.trustedsec.com  
  
It's easy to update using the PenTesters Framework! (PTF)  
Visit https://github.com/trustedsec/ptf to update all your tools!  
  
There is a new version of SET available.  
Your version: 8.0.3  
Current version: 8.1.3  
  
Please update SET to the latest before submitting any git issues.  
  
Select from the menu:  
1) Spear-Phishing Attack Vectors  
2) Website Attack Vectors  
3) Infectious Media Generator  
4) Create a Payload and Listener  
5) Mass Mailer Attack  
6) Arduino-Based Attack Vector  
7) Wireless Access Point Attack Vector  
8) QRCode Generator Attack Vector  
9) Powershell Attack Vectors  
10) Third Party Modules  
  
99) Return back to the main menu.  
set> 2
```

Dentro de este apartado de Ataques Web, se muestra un menú de los métodos del ataque web posibles de implementar, se seleccionó el número 3: **Credential Harvester** que permite recibir la información que es enviada desde un formulario web, para ser transmitida y registrada por un servidor.

```
Session Actions Edit View Help
kali@kali: ~/login-act04

r a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and
harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something differen
t.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to m
ake the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the
malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utiliz
e the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can
be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
```

Configuración e inicialización de Credential Harvester

Posterior a la selección de Credential Harvester, el siguiente menú nos solicitaba el método a utilizar, en este caso se seleccionó **Custom Import** que permite importar nuestra propia página web, tomando en cuenta que sólo debe ser el index.html.

```
Session Actions Edit View Help
kali@kali: -

set:webattack>3

The first method will allow SET to import a list of pre-defined web
applications that it can utilize within the attack.

The second method will completely clone a website of your choosing
and allow you to utilize the attack vectors within the completely
same web application you were attempting to clone.

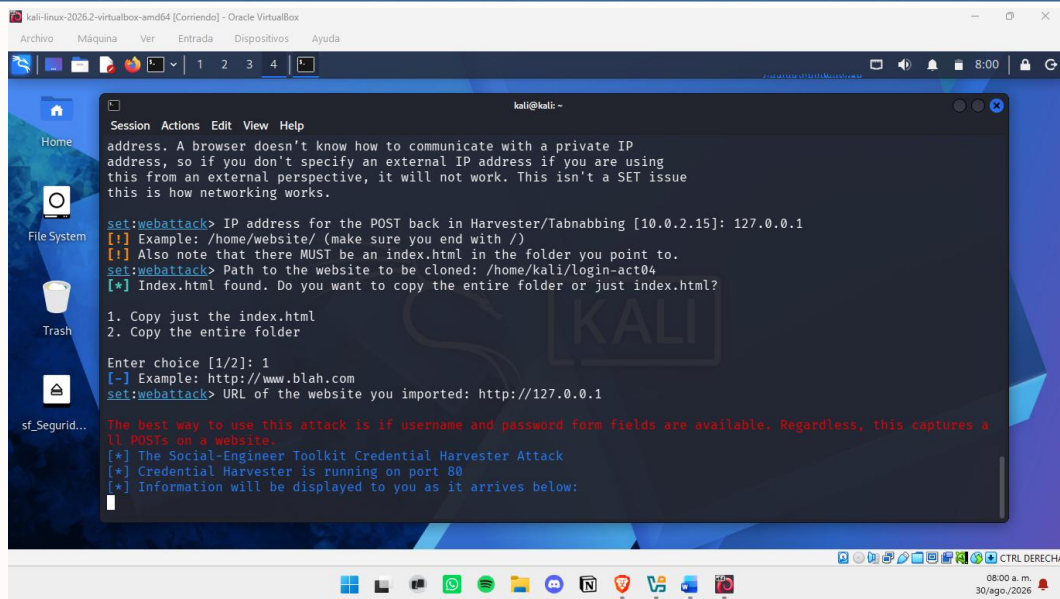
The third method allows you to import your own website, note that you
should only have an index.html when using the import website
functionality.

1) Web Templates
2) Site Cloner
3) Custom Import
99) Return to Webattack Menu
```

Después de seleccionar Custom Import, se configuró SET para que pudiera utilizar la página web desarrollada previamente. Posteriormente, se configuró de la siguiente manera:

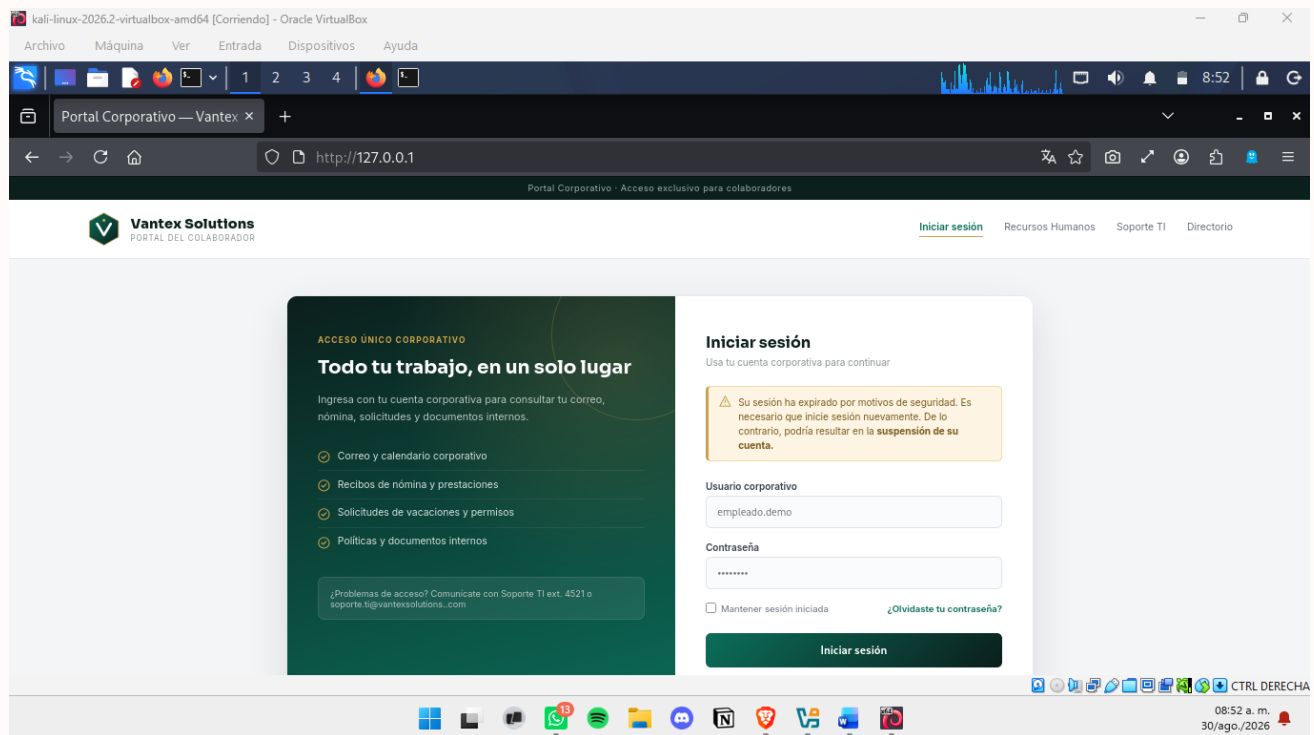
1. Se indicó la dirección *127.0.0.1* como destino para recibir las peticiones enviadas por el formulario.
2. Se especificó la ruta del directorio que contenía el archivo index.html del sitio.
3. Se seleccionó la opción de copiar únicamente index.html.
4. Se indicó la URL local *http://127.0.0.1*, con la finalidad de que el sitio importado funcionara completamente dentro del entorno de laboratorio.

Finalmente, SET inició el módulo **Credential Harvester Attack Method** y quedó escuchando en el puerto 80, listo para recibir y mostrar en pantalla la información enviada mediante el formulario.



Evidencias y descripción del funcionamiento

Una vez iniciado Credential Harvester, se abrió Firefox dentro de la misma máquina virtual y se accedió a la dirección **http://127.0.0.1**. La página de Vantex Solutions fue cargada correctamente desde el servidor local de SET.

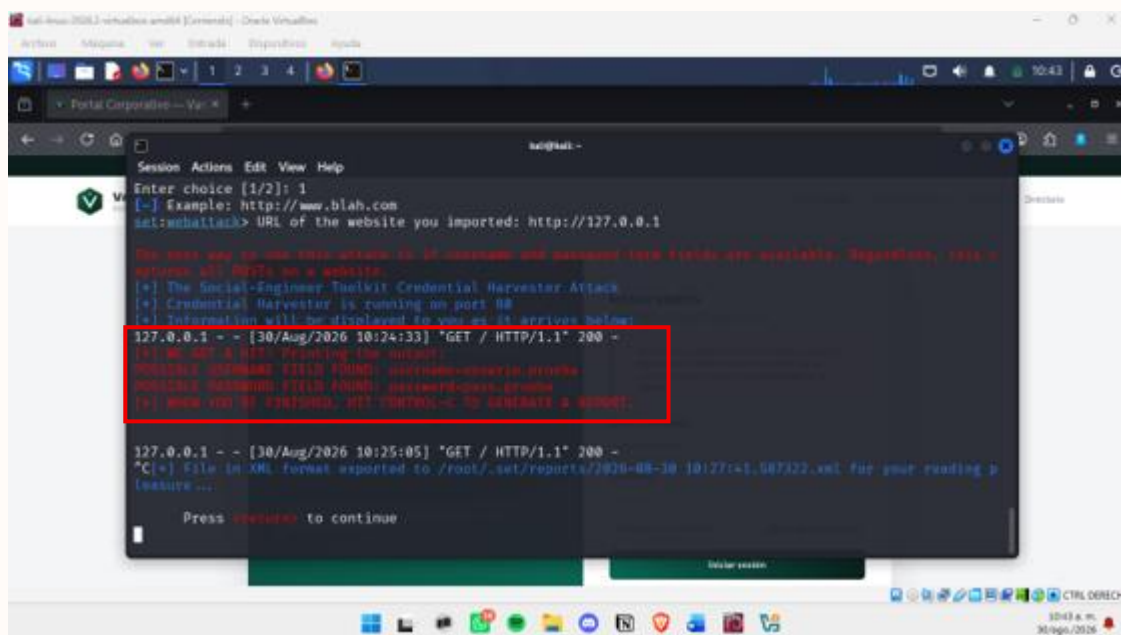


Una vez que Credential Harvester se encontraba ejecutándose y la página se encontraba ya disponible en la dirección, se realizó una prueba utilizando credenciales falsas. En el formulario se introdujo:

- Usuario → usuario.prueba
- Contraseña → pass.prueba

Para posteriormente dar clic en Iniciar Sesión.

Cuando se envió el formulario, SET recibió la información y detectó los parámetros correspondientes al usuario y la contraseña. En la terminal se mostraron los mensajes **POSSIBLE USERNAME FIELD FOUND** y **POSSIBLE PASSWORD FIELD FOUND**, entonces Credential Harvester sí logró procesar los valores enviados desde la página web.



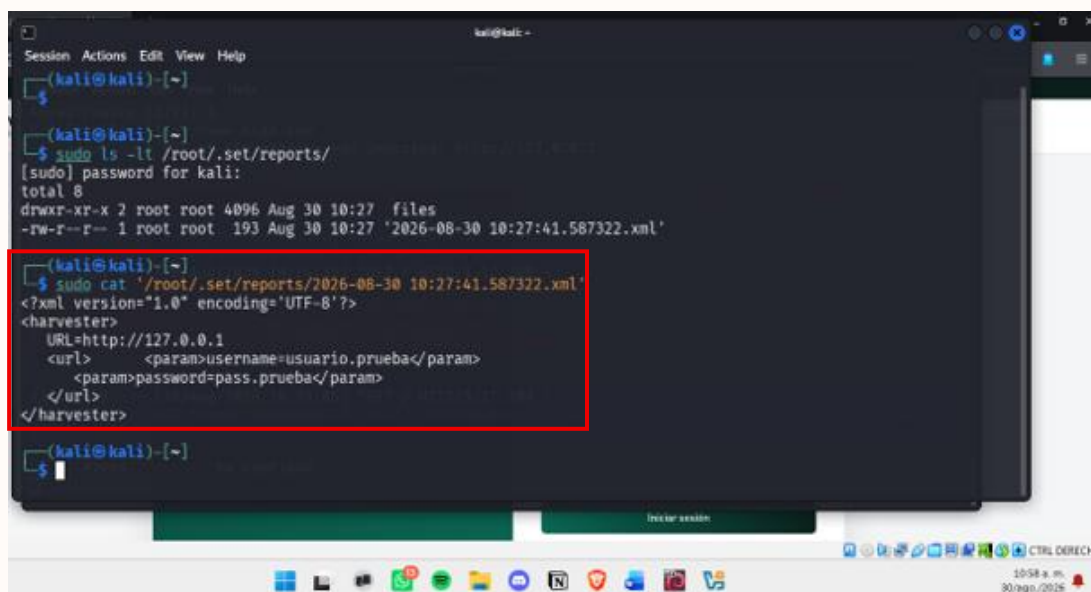
```
kali@kali:~$ sudo set --url http://127.0.0.1 --username usuario.prueba --password pass.prueba
[+] The Social-Engineer Toolkit: Credential Harvester Attack
[+] Credential Harvester is running on port 80
[+] Information will be displayed to you as it arrives below.

127.0.0.1 - - [30/Aug/2026 10:24:33] "GET / HTTP/1.1" 200 -
[+] We got a hit! Printing the output:
POSSIBLE USERNAME FIELD FOUND: usuario=usuario.prueba
POSSIBLE PASSWORD FIELD FOUND: password=pass.prueba
[+] Now you can CTRL+C to generate a report.

127.0.0.1 - - [30/Aug/2026 10:25:05] "GET / HTTP/1.1" 200 -
[+] File in XML format exported to /root/.set/reports/2026-08-30 10:27:41.587322.xml for your reading pleasure...

Press ctrl+c to continue
```

Para terminar la simulación se presionaron las teclas de Ctrl + C, y SET generó automáticamente un archivo de reporte en formato XML dentro del directorio: **/root/.set/reports/**. El archivo generado sí conserva la información registrada durante la sesión, lo que permite comprobar que los datos obtenidos por Credential Harvester permanecen disponibles incluso después de finalizar la ejecución del módulo.



```
(kali@kali)-[~]
$ sudo ls -lt /root/.set/reports/
(sudo) password for kali:
total 8
drwxr-xr-x 2 root root 4096 Aug 30 10:27 files
-rw-r--r-- 1 root root 193 Aug 30 10:27 '2026-08-30 10:27:41.587322.xml'

(kali@kali)-[~]
$ sudo cat '/root/.set/reports/2026-08-30 10:27:41.587322.xml'
<?xml version="1.0" encoding="UTF-8"?>
<harvester>
  URL=http://127.0.0.1
  <curl>
    <param>username=usuario.prueba</param>
    <param>password=pass.prueba</param>
  </curl>
</harvester>
```

Explicación del flujo de captura de información.

El flujo de la simulación inicia cuando el usuario accede a la página ficticia de Vantex Solutions (<http://127.0.0.1>) y escribe datos en los campos de *usuario* y *contraseña*.

El formulario fue configurado con el **método HTTP POST** y con los parámetros *username* y *password*. Al presionar el botón Iniciar sesión, el navegador toma los valores ingresados y genera una petición HTTP dirigida al servidor donde se encuentra la página.

En esta actividad, el servidor se ejecutó localmente mediante **Social-Engineer Toolkit (SET)** en la dirección 127.0.0.1 y el puerto 80. Por lo tanto, la petición no salió hacia Internet, sino que fue enviada desde Firefox hacia el servidor de SET dentro de la misma máquina virtual. Los datos del formulario fueron enviados en el cuerpo de la petición POST, utilizando los nombres definidos en los atributos de los campos.

Una vez recibida la petición, el módulo **Credential Harvester** procesó los parámetros enviados. SET identificó los campos *username* y *password* y mostró en la terminal los valores utilizados durante la prueba:

```
POSSIBLE USERNAME FIELD FOUND: username = usuario.prueba
```

```
POSSIBLE PASSWORD FIELD FOUND: password = pass.prueba
```

Esto comprueba que la información introducida en el formulario llegó correctamente al servidor y fue reconocida por Credential Harvester.

Al finalizar la simulación mediante Ctrl+C, SET generó un archivo de reporte en formato XML dentro del directorio `/root/.set/reports/`. Posteriormente se verificó su contenido y se comprobó que los valores enviados durante la prueba permanecían almacenados como parámetros

```
$ sudo cat '/root/.set/reports/2026-08-30 10:27:41.587322.xml'  
<?xml version="1.0" encoding='UTF-8'?>  
<harvester>  
  URL=http://127.0.0.1  
  <url>    <param>username=usuario.prueba</param>  
    <param>password=pass.prueba</param>  
  </url>  
</harvester>
```

Diagrama del flujo



Diferencia entre captura de credenciales y vulneración de una contraseña

Si bien, esta actividad tuvo como objetivo simular la obtención de las credenciales de un usuario, esto no es una vulneración de contraseña. La diferencia reside en que la vulneración de contraseñas se trata de encontrar el valor de un acceso, mediante métodos como fuerza bruta, ataques de diccionario o ataques de tabla arcoíris.

En cambio, en la captura de credenciales únicamente se registran los valores proporcionados directamente por el usuario. No fue necesario descubrir la contraseña, ya que la información simplemente fue procesada y transmitida mediante la petición enviada por el navegador

Indicadores de phishing

Los ataques de phishing se apoyan principalmente en la ingeniería social para conseguir que el usuario realice una acción, como acceder a un enlace o proporcionar información de autenticación. INCIBE explica que estos ataques pueden partir de mensajes sobre asuntos urgentes que conducen a sitios diseñados para parecer legítimos y solicitar credenciales. CrowdStrike señala además que la recopilación de credenciales mediante phishing suele aprovechar la confianza en organizaciones o marcas para dirigir a la víctima hacia un sitio donde introduce sus datos de acceso.

- **Sentido de urgencia:** Suelen ser mensajes que advierten sobre la suspensión de una cuenta, problemas de seguridad o consecuencias inmediatas que buscan provocar una respuesta rápida antes de que el usuario pueda comprobar la legitimidad de una solicitud.
- **Solicitud inesperada de credenciales o información sensible:** Se puede recibir una petición inesperada para introducir nuevamente una contraseña, verificar el correo electrónico de una cuenta o proporcionar información sensible. Esto debería causarnos desconfianza si nosotros no tuvimos una acción que preceda la solicitud.
- **URL o dominio que no pertenece a la organización:** En ocasiones, una página web puede verse legítima y real, pero el link o el dominio puede que no sea de esa organización, a veces tienen errores ortográficos, o simplemente ni siquiera es cercana al de la organización que dice representar, esto es suficiente para no ingresar ningún dato sensible que pudiera ser comprometido.
- **Enlaces sospechosos o no solicitados:** Algunos ataques de phishing llegan mediante correo electrónico, SMS o redes sociales e incluyen enlaces que aparentan dirigir a sitios legítimos. Sin embargo, el destino real del enlace puede ser diferente al sitio oficial que se espera visitar, por lo que debe verificarse antes de acceder.
- **Inconsistencias en el mensaje o apariencia:** Los errores de redacción, saludos genéricos, formatos que no suelen ser los normales o elementos visuales que no coinciden con los que son utilizados normalmente por una organización, suelen ser señales de una posible suplantación. Esto no quiere decir que una página bien diseñada sea garantía de legitimidad, pero son elementos que deben ser analizados en conjunto a otros indicadores.

Controles de seguridad propuestos.

Los ataques de phishing están presentes en muchos espacios y no debe suponerse que pueden prevenirse con una sola acción. El phishing hace uso de la ingeniería social para engañar a los usuarios y también de mecanismos técnicos para obtener información relevante. Por ello, se recomienda aplicar medidas de prevención en distintos niveles, combinando mecanismos de autenticación, buenas prácticas por parte de los usuarios y herramientas de protección tecnológica.

- **Autenticación multifactor (MFA):** La autenticación multifactor agrega una o más capas de protección además de la contraseña. De esta manera, si un atacante consigue capturar una contraseña mediante phishing, todavía tendría que superar un segundo o incluso un tercer factor para acceder a la cuenta. CrowdStrike recomienda habilitar MFA porque evita que una sola contraseña comprometida sea suficiente para obtener acceso. Sin embargo, no todos los métodos de MFA ofrecen el mismo nivel de protección. Algunos requieren que se introduzcan manualmente códigos OTP y estos aún pueden ser susceptibles a phishing.
- **Uso de gestores de contraseñas y contraseñas únicas:** Utilizar una contraseña diferente para cada servicio ayuda a limitar el daño en caso de que alguna llegue a ser capturada o filtrada. Si una misma contraseña se utiliza en varias cuentas, comprometer una de ellas puede facilitar el acceso a otros servicios. CrowdStrike recomienda utilizar contraseñas seguras y únicas precisamente para reducir este riesgo. Los gestores de contraseñas también pueden ayudar a crear y almacenar claves distintas sin depender de que el usuario se acuerde de todas. Sin embargo, aunque una contraseña sea fuerte y única, esto no evita que el usuario pueda introducirla voluntariamente en una página falsa.
- **Verificación de URL, dominios y canales oficiales:** Antes de introducir credenciales se debe comprobar que la URL realmente corresponda con el dominio oficial. Si un enlace llega de forma inesperada, es más seguro acceder por nuestra cuenta al sitio o verificar esa solicitud por otro medio. También se puede revisar que utilice HTTPS, aunque esto por sí solo no garantiza que la página sea legítima. Aunque ya existen muchos dominios que logran parecer casi idénticos a los originales, así que este control depende aún de lo perspicaz que sea el usuario identificando estos sitios. CrowdStrike y Kaspersky recomiendan verificar tanto el dominio como el origen de la solicitud.
- **Capacitación y concientización de los usuarios:** Educar a los usuarios y brindarles las herramientas necesarias puede ayudar a prevenir que caigan en este tipo de ataques, ya que les permite identificar con mayor facilidad señales relacionadas con phishing. Un usuario informado representa una de las principales defensas frente a ataques dirigidos a credenciales. Aun así, la capacitación reduce el riesgo, pero no elimina el error humano, especialmente porque los ataques actuales pueden estar muy bien diseñados y requieren analizar varios indicadores en conjunto.
- **Mantener sistemas actualizados:** Mantener actualizado el sistema operativo, el navegador y otros programas permite corregir vulnerabilidades conocidas antes de que puedan ser aprovechadas junto con campañas de phishing. La National Cybersecurity Alliance recomienda utilizar versiones actualizadas y aplicar las correcciones de seguridad disponibles. Sin embargo, mantener los sistemas actualizados no evita que un usuario entregue voluntariamente sus credenciales en una página falsa.

- **Filtrado web y protección DNS:** En un entorno empresarial pueden utilizarse filtros de navegación, protección DNS o proxies para bloquear dominios maliciosos antes de que el usuario pueda acceder a ellos. CISA recomienda este tipo de medidas como una barrera adicional frente a enlaces de phishing. Sin embargo, un dominio nuevo o que todavía no haya sido identificado como peligroso podría no ser bloqueado.

Ninguna de estas medidas evita por sí sola todos los ataques de phishing. Lo más conveniente es utilizar varias al mismo tiempo, por ejemplo, combinar la autenticación multifactor, la capacitación de los usuarios y herramientas de protección. Así, si una medida no funciona o el usuario no identifica el engaño, todavía existen otras formas de reducir el riesgo o evitar que las credenciales comprometidas sean suficientes para acceder a una cuenta.

Conclusión.

Esta actividad me pareció sencilla de realizar, pero al mismo tiempo muy ilustrativa, porque demuestra lo relativamente fácil que puede ser obtener información valiosa con muy pocos elementos. Lo que más me llamó la atención fue observar que no siempre es necesario vulnerar técnicamente una contraseña para conseguirla; en muchos casos es el propio usuario quien entrega sus credenciales de manera voluntaria, aunque lo haga sin saber que está siendo engañado.

También me quedó más clara la diferencia entre capturar y vulnerar una contraseña. En la captura, el usuario proporciona directamente la información mediante un formulario, mientras que en la vulneración se busca descubrir la contraseña utilizando otros métodos. Esto me hizo notar todavía más la importancia del factor humano dentro de la seguridad, ya que muchas veces somos nosotros mismos quienes podemos facilitar información sensible si confiamos demasiado rápido en una página o mensaje.

Actualmente considero que identificar un ataque de phishing puede ser cada vez más complicado. Una página bien diseñada puede resultar bastante convincente y, con herramientas actuales que permiten generar contenido más realista, ya no siempre existen errores evidentes que permitan reconocer fácilmente un engaño. Por eso creo que no debemos confiar únicamente en un solo indicador, sino revisar el contexto completo. Por ejemplo, si recibimos una solicitud para restaurar una contraseña que nosotros nunca pedimos, lo más seguro es no proporcionar información y verificar directamente desde el sitio oficial.

Finalmente, no considero que exista un único control capaz de evitar este tipo de ataques. Sin embargo, la capacitación de los usuarios y la autenticación multifactor me parecen dos medidas básicas. El usuario representa una primera línea de defensa y, si llega a caer en el engaño, contar con un factor adicional de autenticación puede disminuir el impacto de las credenciales comprometidas. Esta práctica me ayudó a entender de una forma muy clara lo fácil que puede ser proporcionar información sin pensarlo dos veces y la importancia de mantener una actitud más crítica antes de confiar en una solicitud o introducir datos sensibles.

Referencias.

CrowdStrike. (s. f.). *¿Qué es la recopilación de credenciales?* CrowdStrike.
<https://www.crowdstrike.com/es-es/cybersecurity-101/cyberattacks/credential-harvesting/>

Cybersecurity and Infrastructure Security Agency. (2023). *Phishing guidance: Stopping the attack cycle at phase one*. CISA [PDF]. <https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-cycle-phase-one>

Kaspersky. (s. f.). *¿Qué es el phishing? Cómo detectar y evitar estafas de phishing*. <https://latam.kaspersky.com/resource-center/preemptive-safety/phishing-prevention-tips>

MDN Web Docs. (s. f.). *<form>: El elemento de formulario*. Mozilla. <https://developer.mozilla.org/es/docs/Web/HTML/Reference/Elements/form>

MDN Web Docs. (s. f.). *POST*. Mozilla. <https://developer.mozilla.org/es/docs/Web/HTTP/Reference/Methods/POST>

National Cybersecurity Alliance. (2026) *Qué es el phishing? Cómo identificar y evitar estafas de phishing*. Stay Safe Online. <https://www.staysafeonline.org/es/articulos/suplantación-de-identidad>

Puente García, M. (2022, 5 de mayo). *Con estos ataques nos roban las contraseñas, ¡aprende a evitarlos!* Instituto Nacional de Ciberseguridad. <https://www.incibe.es/empresas/blog/estos-ataques-nos-roban-las-contrasenas-aprende-evitarlos>

NIST (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST Special Publication 800-63B-4). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-63B-4>

SecOps Insider. (2025). *Social Engineering Toolkit (SET): How hackers clone site to harvest credentials* [Video]. YouTube. <https://www.youtube.com/watch?v=J-yzlKocdnI>